Audit E2E Fedpawa Corporate Solutions

Périmètre demandé: première visite du site -> navigation et lecture des pages -> création de compte client -> souscription à chaque service (tous les chemins) -> paiement via API de test -> accès à l'espace client. Rapport consolidé des 4 vagues d'audit (sections S1-S5, espace client F1-F12, workflows W, 2e ronde souscriptions S). Environnement: conteneur dev 127.0.0.1:18081 (miroir de prod www.fedpawa.com) — code en lecture seule, aucune modification. Date: 17 octobre 2026.

1. Synthèse générale

Le site vitrine est solide (contenu soigné, 0 image cassée, pas de placeholders, navigation propre, version EN fonctionnelle) mais la chaîne critique PAIEMENT -> FINALISATION est cassée sur les 6 voies de souscription: l'écran affiche « Paiement confirmé » alors qu'aucune vérification de paiement n'est exécutée — les abonnements restent « en attente » à vie, aucune facture n'est créée, aucun contrat n'est généré, et l'espace client n'offre aucun moyen de finaliser. La sécurité montre une faille critique (OTP de reset exposé dans la réponse HTTP).

A — Création d'entreprise (100 000 F)	**OK (garde, compte, 4 étapes, frais 2%)**	**CASSÉE (en_attente, 0 facture)**
B — OAPI (200 000 F)	OK (204 000 F avec frais)	CASSÉE (en_attente, 0 facture)
C — Fiscalité (35 000 F)	OK (35 700 F)	CASSÉE (en_attente, 0 facture)
D — Contrats (50 000 F)	OK (51 000 F)	CASSÉE (en_attente, 0 facture)
E — Domiciliation via tunnel	Redirection propre vers formulaire dédié	—
F — Domiciliation dédiée (45 000 F/mois)	OK (7 étapes, proforma TVA 19,25%)	CASSÉE (contrat+OTP inatteignables)

2. Parcours testé, étape par étape (2e ronde, 17/10/2026)

2.1 Visiteur -> pages vitrine

9 pages FR + 2 pages EN testées au navigateur: index, création, OAPI, fiscalité, contrats, domiciliation, contact, authentification, tunnel. Toutes en HTTP 200, 0 image cassée, 0 placeholder, 0 fuite de langue FR/EN, H1 corrects, aucune erreur console bloquante. Le tunnel appelé sans paramètre redirige élégamment vers index.php#services; un service inconnu déclenche la garde d'authentification.

2.2 Garde d'authentification et création de compte

Chaque CTA de souscription passe par la garde auth?next=. Inscription réelle via le formulaire UI (civilité, nom, entreprise, forme juridique, téléphone, email, mot de passe + confirmation, CGU): fonctionne, avec toast « Compte créé avec succès ! Connectez-vous. ». Après login, retour exact au point de départ du parcours (next conservé, y compris URLs encodées). Le register n'auto-connecte pas (double saisie, friction S-6).

2.3 Formulaires de souscription et paiement

Tunnel générique (A-D): 4 étapes (Projet, Dirigeant, Documents, Paiement) validées via les boutons réels; la validation bloquante affiche une bannière d'aide et le focus sur le champ manquant. Totaux exacts: frais de transaction 2% corrects sur les 4 services. Paiement Mobile Money en modal (numéro + opérateur Orange) puis écran « Paiement confirmé ». Domiciliation dédiée (F): 7 étapes, upload des pièces KYC (3 fichiers) obligatoire et bien signalé (« Pièce d'identité du représentant légal manquante »), facture proforma avec TVA 19,25% affichée (7 264 F sur 45 000 F), puis paiement.

2.4 Après paiement: vérification base + espace client

Vérifié en base SQLite (lecture seule) après chaque paiement: abonnement créé mais statut « en_attente », table factures vide, table contrats vide, aucun appel à /api/paiement/verifier. L'espace client affiche « En attente » sans aucune action possible (pas de bouton « Vérifier mon paiement », pas de relance). Le OTP de signature renvoyé par le serveur (ex. 949240) n'est jamais demandé à l'utilisateur.

3. Problèmes critiques et majeurs (2e ronde — souscriptions)

S-2 [CRITIQUE] « Paiement confirmé » affiché sans paiement réel — voies A, B, C, D

fedpawa-pay.js (simplePaidFlow) affiche « Paiement confirmé / Votre paiement a bien été reçu / Votre dossier est en traitement » dès que POST /api/souscription répond payment_pending. Aucun appel à /api/paiement/verifier n'est effectué pour les services sans contrat. L'abonnement reste « en_attente » indéfiniment, aucune facture n'est créée, et l'espace client n'offre aucun moyen de finaliser. En mode démo le client croit avoir payé alors que rien n'est enregistré comme payé; en production réelle (Campay) l'écran de confirmation apparaît avant toute confirmation USSD. Correctif: après payment_pending, afficher l'écran de vérification avec bouton « Vérifier mon paiement » (appel /api/paiement/verifier) et un wording « en attente de confirmation » tant que le paiement n'est pas confirmé.

S-3 [MAJEUR] Domiciliation: le flux contrat + signature OTP est inatteignable — voie F

souscription_domiciliation.js passe contract:true à FedpawaPay.momoScreen, mais son onSubmit retourne {ok, message, subscription_ref} sans le champ api attendu par fedpawa-pay.js pour afficher contractFlowScreen (écran « Paiement en cours de confirmation » + bouton « Vérifier mon paiement » + génération du contrat + écran de signature OTP). Résultat E2E: « Souscription enregistrée ! », abonnement en_attente, 0 contrat, l'OTP de signature renvoyé par le serveur n'est jamais consommé. Le seul service prévu pour contrat + signature ne finalise jamais, et le flux n'est atteignable par aucune voie UI (le tunnel redirige vers le formulaire dédié, qui ne déclenche pas contractFlow). Correctif: retourner api: out dans onSubmit (une ligne, comme le fait tunnel.js).

S-1 [MOYEN] CTA global « Je m'abonne » pointe vers un pack inexistant

Le bouton du header présent sur toutes les pages (site-header.php:123, site-header-standalone.html:52) utilise tunnel_souscription.php?service=domiciliation&pack;=essentiel. Or les packs domiciliation valides sont national-essential|business|premium et international-*. Le select arrive vide, aucune pré-sélection, aucun message: l'utilisateur doit deviner qu'il faut choisir un pack. Les 6 CTA de la page domiciliation, eux, fonctionnent. Correctif: pack=national-essential ou retirer le paramètre.

S-4 à S-6 [MINEURS]

S-4: étape 3 OAPI — bouton libellé « Voir le récapitulatif -> » au lieu de « Continuer -> » (incohérence). S-5: civilité requise avec valeur vide par défaut (piège HTML5 léger). S-6: pas d'auto-login après inscription (le next est bien conservé).

4. Espace client — audit dédié (vague 3, F1-F12)

Audit rigoureux de l'espace client (dashboard, profil, documents, factures, contrats, courriers, support) avec comptes de test à différents stades (sans abonnement, avec abonnement). Statut de correction indiqué pour les points déjà repris.

Bouton « Se déconnecter » ne fonctionnait jamais (CSRF + méthode absente)	**CORRIGÉ — vérifié: session fermée, redirec**
Badge « Actif » affiché sans abonnement	CORRIGÉ — aucun badge mensonger sans ab
« Chargement… » éternel (3 emplacements) sans abonnement	PARTIEL — reste sur cartes KYC/Courrier qua
Mobile: profil et déconnexion inaccessibles	CORRIGÉ — burger: MON ESPACE + Se déco
Checkbox « Se souvenir de moi » décoratif	RÉSOLU (retiré de l'UI)
Bouton « Changer de pack » inerte	CORRIGÉ — redirige (mais vers domiciliation:
Aucun historique des tickets	CORRIGÉ — « Mes demandes précédentes »
Tables vides sans message d'état	CORRIGÉ — messages d'état vide affichés
Documents: Statuts et CNI mappés sur le même champ	CORRIGÉ — 4 documents distincts
Pas de limite Sujet/Message	CORRIGÉ — maxLength 150/5000
Inputs sans id / labels sans for	CORRIGÉ — 0/0
Champs connexion sans autocomplete	TOUJOURS OUVERT

5. Workflows utilisateurs (1re ronde, W-1 à W-13)

	CORRIGÉ + vérifié E2E (301 -> 200)
nte vs Actif)	CORRIGÉ + vérifié E2E
cture	CORRIGÉ côté backend (FactureService, vérifié E2E via /api/paiement/verifier) — MAIS la 2e ronde montre que l'UI ne
côté client	CORRIGÉ + vérifié E2E (bouton Répondre admin, badge Répondu client)
	CORRIGÉ (tél + WhatsApp FR/EN)
abonnement)	Ouvert
»	Ouvert
	Ouvert

6. Audit sections S1-S5 (vague 1: contenu, UI, UX, accessibilité, sécurité, SEO)

S1 — Accueil (15 constats)

UX-1	Élevée	Page EN: la majorité des liens internes retombent sur les pages FR
A11Y-1	Élevée	Contraste insuffisant du CTA doré (2.1:1, requis 4.5:1)
SEO-1	Élevée	Aucun tag canonical ni hreflang FR/EN
SEO-2	Élevée	Aucun tag Open Graph / Twitter Card
UX-2	Moyenne	CTA « JE M'ABONNE » mène au tunnel sans présélection
A11Y-2	Moyenne	Texte muted sous le seuil AA (4.21:1)
SEC-1	Moyenne	Headers de sécurité manquants (CSP, X-Frame-Options, Referrer-Policy)
SEO-3/4/5	Moyenne	Title > 60c; description > 160c; images accueil 503KB
FE-1/A11Y-3/4/SEO-6	Basse	favicon 404; cibles tactiles <24px; polices <12px; gratte-ciel 177KB sur mobile

S2 — Pages services (7 constats)

UX-S2-1	Élevée	Pages EN: ~26 liens internes par page retombent en FR
UX-S2-2	Moyenne	Packs domiciliation EN: cards incohérentes
UX-S2-3	Moyenne	CTA des pages services mènent au tunnel SANS présélection du service
FE-S2-1	Basse	Lightbox: img src vide -> requête fantôme
A11Y-S2-1	Moyenne	Titles 86-140c, descriptions 165-228c (tronqués Google)
SEO-S2-1	Moyenne	Poids domiciliation: 803KB dont ~700KB images
SEO-S2-2	Basse	H1 manquant/multiple à vérifier

S3 — Entreprise & Contact (6 constats)

UX-S3-1	Critique	Formulaire de contact FAUX: il n'envoie rien (simulateur JS, aucun backend)
A11Y-S3-1	Élevée	Focus invisible: 6/25 éléments focusables sans indicateur
A11Y-S3-2	Moyenne	Carte WhatsApp: contraste 1.98:1
A11Y-S3-3	Moyenne	Chips 4.21:1 en mode sombre
SEO-S3-1	Moyenne	Titles > 60c
FE-S3-1	Basse	NAV débordante à 375px (sans scroll global)

S4 — Authentification & Espaces (6 constats)

4-1	Critique	FAILLE: OTP de reset renvoyé dans la réponse HTTP (debug_otp) — n'importe qui peut reset n'importe quel
4-2	Élevée	Énumération d'emails possible (réponses différenciées)
4-1	Moyenne	Input email auth: contraste 1.23:1
4-2	Moyenne	Mot de passe oublié: 3 forms sans labels
1	Moyenne	Téléphone non requis au register (incohérence avec le tunnel)

4-1	**Critique**	**FAILLE: OTP de reset renvoyé dans la réponse HTTP (debug_otp) — n'importe qui peut reset n'importe quel**
1	Basse	Console auth: favicon 404 + 403 /api/login au chargement

S5 — Tunnel & SEO global (6 constats)

SEC-S5-1	**Élevée**	**Saut d'étape bloqué (bien) mais aucun message d'erreur expliqué**
UX-S5-1	Moyenne	Tunnel contrats: 50 000 F affiché étape 1 puis 100 000 F étape 3
UX-S5-2	Élevée	Étape 3 (documents) BLOQUANTE sans explication: 0 champ visible, aucun bouton
SEO-S5-1	Élevée	sitemap.xml pointe vers www.fedpawacorporatesolutions.com — DOMAINE DIFFÉRENT
SEO-S5-2	Moyenne	robots.txt absent (404)
FE-S5-1	Basse	favicon 404 persistant sur tunnel

7. Ce qui fonctionne bien (vérifié)

• Garde d'authentification systématique avec next= fidèle, même en pleine souscription, y compris URLs encodées. • Frais de transaction 2% calculés et affichés correctement sur les 4 services (102 000 / 204 000 / 35 700 / 51 000). • Facture proforma domiciliation: TVA 19,25% affichée, totaux justes, validation bloquante avec messages précis et scroll automatique. • 9 pages FR + 2 EN: 0 image cassée, 0 placeholder, 0 fuite de langue, H1 corrects. • Redirection tunnel sans service -> index.php#services; service inconnu -> garde auth. • Corrections W-2/W-9/W-13/W-3 vérifiées E2E et déployées en production (commit e16a83c). • Throttle login, CSRF, sessions: aucune erreur JS bloquante sur l'ensemble du parcours.

8. Priorités de correction recommandées

P1	**S-2: écran de vérification de paiement pour les 4 services du tunnel (fin de la fausse confirmation)**	**Moyen**
P1	SEC-S4-1: retirer debug_otp de la réponse HTTP	Très faible
P2	S-3: retourner api dans onSubmit domiciliation (débloque contrat+signature)	Très faible
P2	UX-S3-1: brancher le formulaire de contact sur un backend	Moyen
P2	SEO-S5-1: corriger le domaine du sitemap.xml	Très faible
P3	S-1: pack du CTA header (national-essential)	Très faible
P3	W-6/W-12/F4/F9: guidance premier usage, courriers lus, profil mobile, mapping documents	Moyen

9. Espace client post-paiement — re-vérification après correctifs (17/10/2026)

Audit post-paiement réalisé en UI réelle (client payé + client sans abonnement + vue mobile 375px + réponse admin): W-9 (statut ACTIF cohérent Aperçu/Abonnement), W-10 (facture FAC-DEMO-SUB-81 créée et visible dans Mes factures) et W-13 (réponse admin visible: statut RÉPONDU + réponse + date) re-validés. F1, F2, F4, F5, F6, F7, F8, F9, F10, F11 corrigés et vérifiés. Restent: F3 partiel (cartes KYC/Courrier: « Chargement… » persistant quand vide), F12 (autocomplete), et le ciblage du bouton « Changer de pack » (redirige vers la domiciliation quel que soit le service). Détails: audit/espace_client_post_w.md.